Vulnerability Assessment report for https://preview.owasp-juice.shop/#/

Date: 02/04/2026

Task: 01

Table of Content

Table of Content 2
Disclaimer 3
Contact Information 3
Assessment Overview 3
Phases of assessment included the following 3
Risk Criteria 4
Executive Overview.....4
Scope & methodology.....4
Tools.....4
Key Findings 4
Vulnerability Summary Table.....5 & 6
Detailed Findings.....7
1.Nmap Findings.....7
1.1 Port 21(FTP Risk).....8
1.2 Port 80(HTTP Proxy) & Port 8080(HTTP Proxy.....8
1.3 Port 443(HTTPS).....8
1.4 Filtered Ports (53 DNS, 515 Printer).....8
2.Owasp ZAP.....9 & 10
2.1. Application closure.....11
2.2. Content Security Policy (CSP) Header Not Set.....11
2.3. Cross-Domain Misconfiguration 12
2.4. Missing Anti-clickjacking Header.....12
2.5.Session ID in URL Rewrite.....13
2.6.Information Disclosure - Debug Error Messages 13

2.7.Private IP Disclosure.....13
2.9.Timestamp Disclosure – Unix.....14
2.10.X-Content-Type-Options header not set.....14
2.11.Retrieved from Cache.....15

Disclaimer

This vulnerability test is a snapshot in time, Therefore the finding and solutions are a result of the information gathered at the time of the assessment and not to any changes made after that time. I only conducted read only analysis and recommend that different approaches are taken to ensure the security of the website such as pen testing and etc.

Contact Information

Vulnerability assessor: Nemukula Diphathutshedzo
Cellphone: 0788524431
Email: nemukuladziphathutshedzo44@gmail.com

Assessment Overview

I was tasked with conducting Vulnerability assessment on any public demo and I choose the https://preview.owasp-juice.shop/#/ website by Owasp and all the testing was read-only-Assessment and was performed using Nmap, OWasp Zap and Browser Developer Tools

Phases of assessment included the following:

Preparations- Downloaded all necessary tools
Analysis- Used the tools to perform a read-only analysis on the website
Documentation- Analyzed, and then documented the results using Canva

Risk Criteria

Critical: Full system compromise, credential theft, data breach
High: Unauthorized access, impersonation, infrastructure exposure
Medium: Information leakage, misconfigurations, reduced resilience
Low: Debug info, timestamps, headers missing

Executive Overview

The purpose of this assessment is to find out all the vulnerabilities of this website with the use of Read-Only tools, Without any form of attack. This website is currently exposed to several vulnerabilities that could lead to unauthorized access and data leakage, and I recommend that critical issues be addressed immediately because they are related to the direct compromise of sensitive data.

Scope & Methodology

Scope: Public pages only, passive scanning, header checks, configuration analysis.
Excluded: No login bypass, exploitation, brute force, DoS, or any harmful activity.
Methodology: Act as a security auditor – identify weaknesses without exploiting them

Tools

Nmap-Basic port scan to identify open services
Owasp-Detect missing headers, insecure cookies, hidden comments

Key Findings:

Total Records: 15
Critical: 0
High:4
Medium:7
Low: 4

Vulnerability Summary Table

Sl. no	Action	Recommendation	Severity
1.1	Port 21 (FTP Risk)	Turn off port 21 since no file transfer is required	High
1.2	Port 80 & 8080 (HTTP Proxy)	Hide server information, secure port 8080, and keep	Medium
1.3	Port 443 (HTTPS)	Hide version info and keep systems updated	Medium
1.5	Filtered Ports (53 DNS, 515 Printer)	Restrict internal access, update internal services, and	Medium
1	Application Closure	Implement custom error pages with unique error identifiers,	Medium
2	CSP Header Not Set	Configure servers to set Content-Security-Policy	Medium
3	Cross-Domain Misconfiguration	Remove or restrict CORS headers to trusted domains	High
4	Missing Anti-Clickjacking Header	Configure X-Frame-Options or CSP frame-ancestors directive	Medium
5	Session ID in URL Rewrite	Store session IDs in cookies, remove from URLs	High

6	Information Disclosure – Debug Error Messages	Disable debugging messages	Low
7	Private IP Disclosure	Remove private IPs from response body, use server-side comments	Low
8	Strict-Transport-Security Header Not Set	Configure servers to enforce HSTS	Medium
9	Timestamp Disclosure – Unix	Remove timestamp from responses	Low
10	X-Content-Type-Options Header Not Set	Set Content-Type correctly and include X-Content-Type-Options: nosniff	Medium
11	Retrieved from Cache	Use HTTP headers (Cache-Control, Pragma, Expires) to prevent sensitive caching	Medium

Read-Only-Analysis Findings

1. Nmap Findings

Zenmap

Scan Tools Profile Help

Target: preview.owasp-juice.shop Profile: Scan Cancel

Command: nmap -sS -sV preview.owasp-juice.shop

Hosts Services

OS Host

preview.owasp-

Nmap Output Ports / Hosts Topology Host Details Scans

nmap -sS -sV preview.owasp-juice.shop Details

```
Starting Nmap 7.99 ( https://nmap.org ) at 2026-03-31 14:22 +0200
Nmap scan report for preview.owasp-juice.shop (81.169.145.156)
Host is up (0.20s latency).
Other addresses for preview.owasp-juice.shop (not scanned): 2a01:238:20a:202:1156::
rDNS record for 81.169.145.156: w9c.rzone.de
Not shown: 994 closed tcp ports (reset)
PORT      STATE    SERVICE    VERSION
21/tcp    open     ftp        ftpd.bin round-robin file server 3.4.0r16
53/tcp    filtered domain
80/tcp    open     http-proxy F5 BIG-IP load balancer http proxy
443/tcp   open     ssl/http   Apache httpd 2.4.66 ((Unix))
515/tcp   filtered printer
8080/tcp  open     http-proxy F5 BIG-IP load balancer http proxy
Service Info: Device: load balancer

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 40.56 seconds
```

Filter Hosts

Breaking news
R3-per-litre cut t...

Search

ENG
US

14:27
2026/03/31

1.1 Port 21(FTP Risk)

Description: User credentials are not encrypted and can be easy comprised. And some may be misconfigured to allow anonymous access allowing attackers to download sensitive data.

Impact: high

System: https://preview.owasp-juice.shop/#

Solution: Turn off port 21 since there is no upload/download of files on the site.

1.2 Port 80(HTTP Proxy) & Port 8080(HTTP Proxy)

Description: It reveals the layout or misconfigurations of the infrastructure.

Impact: Medium

System: https://preview.owasp-juice.shop/#

Solution: Hide the server information, secure port 8080 and keep firmware updated

1.3 Port 443(HTTPS)

Description: Tells attacks the web server and version which can help attackers match exploits

Impact: Medium

System: https://preview.owasp-juice.shop/#

Solutions: Hide version info and keep the systems updated

1.4 Filtered Ports(53 DNS, 515 Printer)

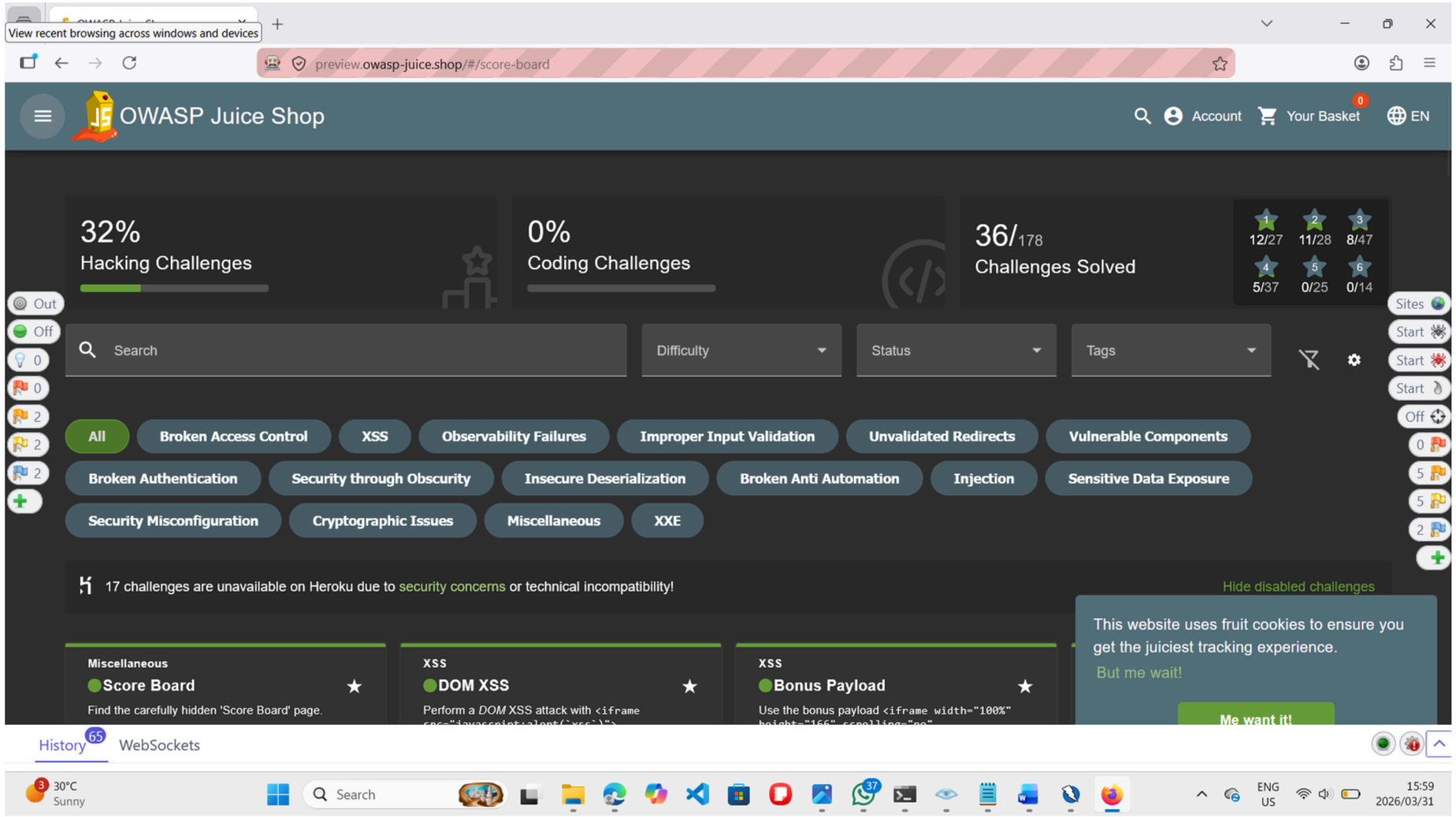
Description: They reveal potential pivot points by exposing services that exist internally

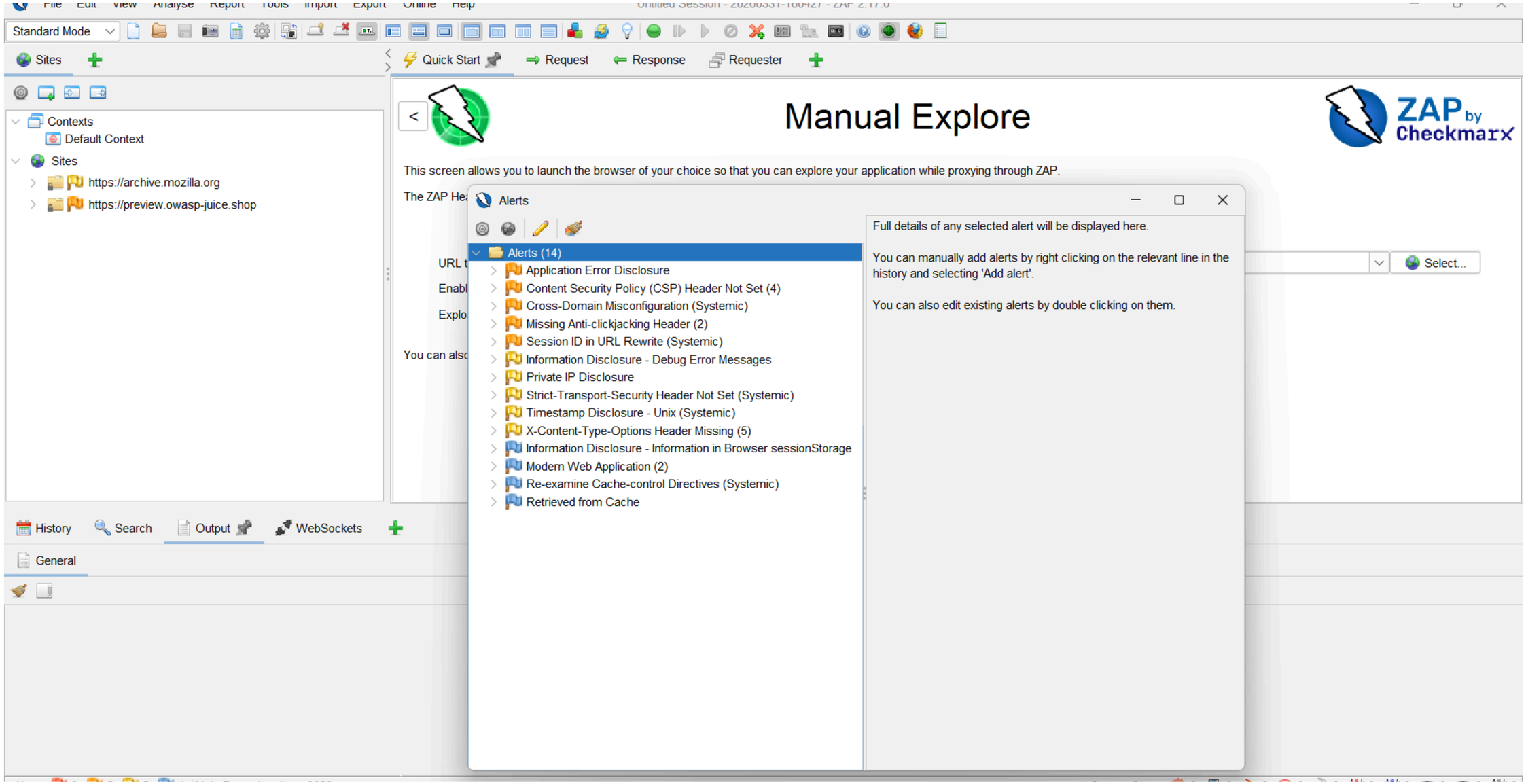
Impact: Medium

System: https://preview.owasp-juice.shop/#

Solution: Restrict internal access, update the internal services software and monitor internal traffic.

2.Owasp ZAP


View recent browsing across windows and devices
preview.owasp-juice.shop/#/score-board
OWASP Juice Shop
Account
Your Basket
EN
32%
Hacking Challenges
0%
Coding Challenges
36/178
Challenges Solved
12/27
11/28
8/47
5/37
0/25
0/14
Search
Difficulty
Status
Tags
All
Broken Access Control
XSS
Observability Failures
Improper Input Validation
Unvalidated Redirects
Vulnerable Components
Broken Authentication
Security through Obscurity
Insecure Deserialization
Broken Anti Automation
Injection
Sensitive Data Exposure
Security Misconfiguration
Cryptographic Issues
Miscellaneous
XXE
17 challenges are unavailable on Heroku due to security concerns or technical incompatibility!
Hide disabled challenges
Miscellaneous
Score Board
Find the carefully hidden 'Score Board' page.
XSS
DOM XSS
Perform a DOM XSS attack with
XSS
Bonus Payload
Use the bonus payload
This website uses fruit cookies to ensure you get the juiciest tracking experience.
But me wait!
Me want it!
History
WebSockets
30°C
Sunny
Search
ENG
US
15:59
2026/03/31


File Edit View Analyse Report Tools Import Export Online Help
Standard Mode
Sites
Quick Start
Request
Response
Requester
Contexts
Default Context
Sites
https://archive.mozilla.org
https://preview.owasp-juice.shop
Manual Explore
ZAP by Checkmarx
This screen allows you to launch the browser of your choice so that you can explore your application while proxying through ZAP.
Select...
History
Search
Output
WebSockets
General
Alerts
Alerts (14)
Application Error Disclosure
Content Security Policy (CSP) Header Not Set (4)
Cross-Domain Misconfiguration (Systemic)
Missing Anti-clickjacking Header (2)
Session ID in URL Rewrite (Systemic)
Information Disclosure - Debug Error Messages
Private IP Disclosure
Strict-Transport-Security Header Not Set (Systemic)
Timestamp Disclosure - Unix (Systemic)
X-Content-Type-Options Header Missing (5)
Information Disclosure - Information in Browser sessionStorage
Modern Web Application (2)
Re-examine Cache-control Directives (Systemic)
Retrieved from Cache
Full details of any selected alert will be displayed here.
You can manually add alerts by right clicking on the relevant line in the history and selecting 'Add alert'.
You can also edit existing alerts by double clicking on them.

2.1 Application closure

Description: This page contains an error message that discloses sensitive information that can be used to launch an attack like the location of files that produces unhandled expections

Impact: Medium

System: https://preview.owasp-juice.shop/api/Hints/

Solution: They should create an error message page and create a unique error identifier for each incident while the full technical information is securely stored in the server.

2.2 Content Security Policy (CSP) Header Not Set

Description: The web application does not have a csp set, Which makes it vulnerable to attacks like Cross Site Scripting (XSS) and data injection attacks which are used in things like data theft, site defimation and malware distribution.

Impact: Medium

System: GET: https://preview.owasp-juice.shop/

GET: https://preview.owasp-juice.shop/assets/public/images/uploads/ᓚᘏᗢ-

POST: https://preview.owasp-juice.shop/socket.io/ (EIO,sid,t,transport)(1)

POST: https://preview.owasp-juice.shop/socket.io/ (EIO,sid,t,transport)(3)

POST: https://preview.owasp-juice.shop/socket.io/ (EIO,sid,t,transport)(40)

Solution: Configure the web, application servers and ect to set the content-security-policy header

2.3 Cross-Domain Misconfiguration

Description: The website has a Cross Origin Resource Sharing(CORS) misconfiguration which can allow attackers to read responses from authorised APIs or available data in an unauthorized manner.

Impact: Medium

System: GET:https://preview.owasp-juice.shop/

Solution: Remove all CORS headers entirely or configure the Access-control-allow-origin http header to more strict set of domains.

2.4 Missing Anti-clickjacking Header

Description: There is no Content-Security-Policy with 'frame-ancestors' directive or X-Frame-Options which creates the risk of clickjacking attacks

Impact: Medium

System: GET:https://www.herokucdn.com/error-pages/application-error.html

Solution: Ensure that all the pages of the web-application have a protective http header that stops clickjacking by configuring x-frame-options or Content-Security-Policy (CSP) frame-ancestors directives.

If the page is only meant to be framed

by same site use: SAMEORIGIN

if its never to be framed use: DENY

Alternatively consider implementing Content Security Policy's "frame-ancestors" directive

2.5 Session ID in URL Rewrite

Description: Session ID is embedded in URL and can be accessed by third party sites and user can copy and share it leading to impersonation and leaking of sensitive data.

Impact: High

System:GET:https://preview.owasp-juice.shop/socket.io/ (EIO,sid,t,transport)

Solution: Use a combination of cookies and URL rewrite to store the session id and remove them from the url.

2.6 Information Disclosure - Debug Error Messages

Description: The web application returns detailed debug error messages which reveal internal information such as file paths, data enquiries and framework version which attackers can use to plan a targeted attack

Impact: Low

System: GET:https://preview.owasp-juice.shop/api/Hints/

Solution: Disable all debugging messages

2.7 Private IP Disclosure

Description: The private ip address can be found in the html body

Impact: Low

System: GET:https://preview.owasp-juice.shop/rest/admin/application-configuration

Solution: Remove the private ip address from the http response body and use JSP/ASP/PHP comment instead of HTML/JavaScript comment.

2.8 Strict-Transport-Security Header Not Set

Description: There is no web security policy describing which declares which user agents with a certain type of connection(e.g https) can interact with the web server

Impact: Low

System:GET:https://preview.owasp-juice.shop/chunk-OQW3DWJW.js
GET:https://preview.owasp-juice.shop/scripts.js

Solution: Ensure that your web server, application server, load balancer, etc. is configured to enforce Strict-Transport-Security

2.9 Timestamp Disclosure – Unix

Description: The website discloses unix timestamps which attacks can use to see the patch cycle for serves and aid in profiling the environment

Impact: Low

System:GET:https://preview.owasp-juice.shop/

Solution: Remove the timestamp

2.10 X-Content-Type-Options header not set

Description: There is no set content-type which may allow attackers to use older versions of internet explorers to trick the webserver to process executable code(e.g java scripts) instead of treating them as plain text.

Impact: Medium

System: GET:https://preview.owasp-juice.shop/socket.io/ (EIO,sid,t,transport)

Solution: Configure the web application to ensure that the Content-Type header is set correctly and includes X-Content-Type-Options: nosniff header in all responses

2.11 Retrieved from Cache

Description: The application responses are retrieved from a shared cache which may leak sensitive information shared by users and allow other users or attacks to gain control of others sessions or sensitive information.

Impact: Low

System: GET:https://archive.mozilla.org/pub/system-addons/newtab/newtab-151.2.0-build1/newtab.xpi

Solution: Make sure that the responses do not contain sensitive or user-specific information.

If it does use http response headers to prevent the content from being stored or being retrieved by another user by using:

Cache-Control: “no-cache” , “no-store” , “must-revalidate” , “private”

Pragma: “no-cache”